

TOTAL TRACKER

Audit statico di sicurezza, prestazioni, affidabilit  e manutenibilit 

Baseline	87a2b8d58dea240f0b4b69dddc76e620b1a4729
Branch esaminato	feature/0.1.0-06-ui-measurement-performance-docs
Versione app	0.1.0+19
Data	8 luglio 2026
Metodo	Revisione statica mirata + evidenze di build/test disponibili
Classificazione	Confermato / Plausibile / Debito tecnico

Avvertenza. Questo documento non   un penetration test, non certifica la sicurezza del prodotto e non dimostra sfruttabilit  su dispositivo reale. Le conclusioni derivano dal codice pubblico e dai log di validazione disponibili alla data indicata. I rilievi plausibili richiedono riproduzione dinamica prima di essere trattati come vulnerabilit  confermate.

Documento destinato alla pianificazione tecnica e alla preparazione della release. Non contiene dati utente reali.

1. Sintesi esecutiva

La baseline e la patch 0.1.0_06 mostrano un livello di hardening superiore a un prototipo tipico: limiti sugli input, checksum, allow-list ZIP, controlli immagini, HTTPS, firma Ed25519, soft delete, import in due fasi, ricalcolo incrementale persistente e una suite di 189 test passata. Le debolezze principali non sono assenza totale di controlli, ma confini di fiducia e scalabilità ancora incompleti.

Gravita	Numero	Interpretazione
Alta	4	Intervento prioritario prima della release pubblica
Media	14	Rischio concreto o debito significativo da pianificare
Bassa	3	Hardening/governance non bloccante

Rischi dominanti. Gli export non cifrati e la possibilità di cambiare gateway e chiave di trust in una release sono i due rilievi più urgenti. Sul piano prestazionale, l'export usa scansioni `getAll()` annidate e materializza intere strutture/archivi in memoria, con crescita sfavorevole su storici lunghi.

Giudizio complessivo. Idonea a continuare lo sviluppo e i test interni; non ancora pronta a essere presentata come applicazione pubblica sicura per dati personali senza chiudere le priorità P0 e svolgere test dinamici su dispositivi reali.

Controlli positivi osservati

- Android Auto Backup e device-transfer extraction risultano disabilitati.
- Il traffico clear-text Android è disabilitato e il gateway richiede HTTPS.
- Le risposte OpenNutrition sono soggette a firma Ed25519, schema noto, freschezza e limiti.
- Gli archivi applicano allow-list, rifiuto duplicati/path traversal, checksum SHA-256 e limiti anti-DoS.
- Le immagini sono limitate per byte, dimensione e pixel e validate tramite magic bytes.
- Il ricalcolo target usa invalidazioni persistenti, single-flight, coalescenza, hash degli input e recovery.
- Il probe della patch precedente ha superato analyze, 12 test mirati, 189 test completi e build Android debug.
- La patch 0.1.0_06 elimina un pattern N+1, rende non modale il picker e rimuove i tagli silenziosi dello storico misurazioni.
- Le importazioni mostrano anteprima e conflitti prima della scrittura definitiva.

Piano prioritario

Livello	Azione
P0	Disabilitare custom gateway in release e fissare host/key di produzione.
P0	Progettare export cifrato e autenticato con recovery/migrazione documentati.
P1	Rimuovere <code>getAll()</code> annidati e introdurre export/import streaming o chunked.
P1	Decodificare/ricodificare immagini e rimuovere EXIF/XMP.
P1	Decidere threat model e strategia di cifratura del database locale.
P1	Introdurre benchmark, fault injection e test su dispositivi reali.
P1	Misurare la query ingredienti e verificare picker/grafici su schermi piccoli e storici grandi.

Livello	Azione
P1	Pianificare migrazione Built-in Kotlin e aggiornamento plugin.
P2	Spezzare i servizi monolitici e riallineare la documentazione annidata.
P2	Aggiungere SBOM, advisory scanning, licenze e policy di aggiornamento.

2. Perimetro e metodo

Oggetto della revisione

- Repository Total Tracker sul commit base 87a2b8d58dea240f0b4b69dddc76e620b1a4729 e payload proposto 0.1.0_06.
- Applicazione Flutter/Dart, configurazione Android, ObjectBox, import/export, immagini, gateway OpenNutrition, target incrementale, dipendenze e test.
- Log di applicazione patch che attestano analyze, test mirati, 189 test completi e build APK debug superati.

Attività svolte

- Revisione mirata del codice e dei documenti pubblici del commit.
- Analisi dei confini di fiducia, dati a riposo, rete, file importati, immagini e configurazioni.
- Ricerca di pattern di costo elevato: letture complete, loop annidati, copie in memoria e transazioni lunghe.
- Confronto con OWASP MASVS/MASTG, raccomandazioni Android, Flutter performance e documentazione ObjectBox.
- Classificazione separata tra evidenza confermata, rischio plausibile e debito tecnico.

Esclusioni e limiti

- Nessuna esecuzione di exploit, fuzzing, MITM, reverse engineering dell'APK o test su dispositivo rooted.
- Nessuna scansione completa CVE/SCA del lockfile e nessuna SBOM generata in questo audit.
- Nessun benchmark profile/release con dataset grandi; i rilievi prestazionali derivano dai pattern di codice.
- Nessuna valutazione legale o medica dei calcoli nutrizionali.
- Il gateway server e i dataset OpenNutrition non sono stati sottoposti a penetration test.

Scala della gravità

Livello	Criterio
Alta	Esposizione rilevante o blocco grave probabile; priorità prima della release pubblica.
Media	Impatto concreto dipendente da volume, configurazione o threat model.
Bassa	Rischio residuo, hardening o governance con impatto limitato.

3. Architettura e superfici di attacco

Flussi principali

- UI Flutter -> provider Riverpod -> servizi/repository -> ObjectBox locale.
- File esterni -> selezione utente -> parser/validator -> anteprima -> transazione di import.
- Database -> struttura di export -> codec ZIP/JSON -> file .totaltracker in directory scelta.
- Query alimentare -> HTTPS -> Open Food Facts o gateway OpenNutrition firmato.
- Immagine locale/remota -> controlli -> storage applicativo -> rendering UI.
- Mutazione target -> invalidazione persistente -> coordinatore -> ricalcolo cronologico -> snapshot.

Asset sensibili

- Profilo e dati antropometrici.
- Diario alimentare e preferenze.
- Peso, composizione corporea e misure.
- Allenamenti, routine e sessioni.
- Archivi di backup e immagini.
- Configurazione del gateway e radice di fiducia.

Attori e scenari considerati

- Utente legittimo che condivide accidentalmente un export o una foto con metadati.
- File importato malevolo o eccessivamente grande.
- Servizio remoto o host immagine non fidato.
- Applicazione in esecuzione su dispositivo compromesso/sbloccato.
- Dataset molto grande che provoca esaurimento memoria o UI non responsiva.
- Aggiornamento SDK/plugin che interrompe la build.

Difese già presenti

Le difese osservate sono reali e devono essere preservate durante le correzioni: limiti di input, parser bounded, controlli ZIP, HTTPS, firma, transactional write, soft delete, test security-focused, CI e worktree probe. Le raccomandazioni seguenti non giustificano la rimozione di tali controlli.

4. Registro sintetico dei rilievi

ID	Gravita	Stato	Titolo
SEC-01	Alta	Confermato	Gli archivi .totaltracker non sono cifrati
SEC-02	Alta	Confermato	Gateway OpenNutrition personalizzabile in produzione per impostazione predefinita
SEC-03	Media	Confermato	Database ObjectBox locale senza cifratura applicativa
SEC-04	Media	Plausibile	Immagini remote consentite da host HTTPS arbitrari
SEC-05	Media	Confermato	Foto locali persistite senza rimozione dei metadati
SEC-06	Bassa	Plausibile	Validazione immagini basata principalmente sugli header
SEC-07	Media	Debito tecnico	Governance dipendenze e supply chain incompleta
PERF-01	Alta	Confermato	Export con getAll() annidati e complessita moltiplicativa
PERF-02	Alta	Confermato	Import/export materializza archivi e strutture complete in memoria
PERF-03	Media	Confermato	Applicazione import in una singola transazione sincrona lunga
PERF-04	Media	Debito tecnico	File applicativi monolitici aumentano costo e rischio di regressione
PERF-05	Media	Debito tecnico	Mancano benchmark e profili su dataset grandi
REL-01	Media	Confermato	Migrazione Kotlin richiesta da future versioni Flutter
REL-02	Media	Confermato	Documentazione interna obsoleta e contraddittoria
REL-03	Media	Plausibile	Configurazione sensibile del gateway in SharedPreferences
TEST-01	Media	Debito tecnico	Copertura insufficiente per fault injection, crash recovery e carico
GOV-01	Bassa	Debito tecnico	Licenza del repository non esplicitata nel perimetro esaminato
PERF-06	Media	Confermato	Scheda alimento rallentata da letture N+1 dello storico pasti
REL-04	Media	Confermato	Bottom sheet alimenti modale anche quando visivamente compressa
REL-05	Media	Confermato	Grafici e cronologia misurazioni troncavano dati senza dichiararlo
REL-06	Bassa	Confermato	Drift di pubspec.lock blocca le patch senza una politica di preservazione

5. Sicurezza e privacy

SEC-01 - Gli archivi .totaltracker non sono cifrati

Gravita	ALTA	Stato	Confermato
Categoria	Riservatezza / export	Priorita	P0 - prima di una release pubblica con export abilitato.

Evidenza. docs/SECURITY_AND_RELEASE_CHECKLIST.md;
lib/features/transfer/data/total_tracker_transfer_service.dart; formato .totaltracker v2.

Analisi. Il formato applica SHA-256, allow-list delle entry, limiti ZIP/JSON e analisi dei conflitti, ma il contenuto rimane leggibile da chiunque ottenga il file. Il checksum non è una firma e può essere ricalcolato da un attaccante che modifica l'archivio e manifesta.

Impatto. Esposizione di profilo, alimentazione, peso, composizione corporea, misure e allenamenti attraverso condivisione, cloud drive, backup manuali o file manager.

Raccomandazione. Introdurre una versione cifrata e autenticata: derivazione password memory-hard (Argon2id o scrypt, oppure PBKDF2 con parametri documentati) e AEAD (XChaCha20-Poly1305 o AES-GCM). Salvare sale, versione e parametri nel contenitore; non inventare una chiave solo dispositivo per un formato pensato per il ripristino cross-device.

SEC-02 - Gateway OpenNutrition personalizzabile in produzione per impostazione predefinita

Gravita	ALTA	Stato	Confermato
Categoria	Integrità / rete / configurazione	Priorita	P0 - chiudere prima di distribuire una build pubblica.

Evidenza. Configurazione OpenNutrition: OPENNUTRITION_ALLOW_CUSTOM_GATEWAY ha default abilitato; URL, key ID e chiave pubblica possono essere caricati da preferenze runtime.

Analisi. La firma Ed25519 protegge la risposta solo rispetto alla chiave considerata fidata. Se una build release consente di cambiare contemporaneamente endpoint e chiave pubblica, l'utente o un attore con accesso alla configurazione può sostituire l'intera radice di fiducia e far accettare dati prodotti da un server arbitrario.

Impatto. Avvelenamento del catalogo, valori nutrizionali falsi, tracciamento delle query e perdita della garanzia di pinning attesa dal gateway firmato.

Raccomandazione. Impostare il default a false nelle release. Iniettare host, key ID e chiave pubblica con dart-define o file di configurazione firmato. Limitare la configurazione runtime a build debug o a un developer mode esplicito, con allow-list e avviso non aggirabile.

SEC-03 - Database ObjectBox locale senza cifratura applicativa

Gravita	MEDIA	Stato	Confermato
Categoria	Dati a riposo	Priorita	P1 - decisione architetturale prima della release stabile.

Evidenza. lib/core/database/objectbox_database.dart apre lo Store nella directory documenti senza encryption key; la checklist dichiara ancora aperta la decisione sulla cifratura.

Analisi. Il sandbox Android riduce l'accesso tra applicazioni e Auto Backup e disabilitato, ma i dati restano leggibili su dispositivo sbloccato, rooted, compromesso o durante acquisizione forense. I dati trattati hanno natura personale e in parte sanitaria.

Impatto. Esposizione locale dell'intero storico. Il rischio dipende dal threat model e dal livello di compromissione del dispositivo.

Raccomandazione. Definire formalmente il threat model. Valutare cifratura del database o dei campi più sensibili con chiave protetta dal Keystore/Keychain; documentare limiti di recovery e migrazione. Evitare di promettere protezione contro un processo applicativo già compromesso.

SEC-04 - Immagini remote consentite da host HTTPS arbitrari

Gravita	MEDIA	Stato	Plausibile
Categoria	Privacy / rete	Priorita	P1 - prima di ampliare fonti o condivisione di ingredienti.

Evidenza. Servizio immagini ingredienti: controllo HTTPS, host sintattico, no localhost/IP letterale; nessuna allow-list di domini e nessuna verifica documentata della risoluzione DNS finale.

Analisi. Un URL immagine controllato da terzi può osservare IP, orari, user-agent e frequenza di apertura. I controlli lessicali non escludono necessariamente hostname pubblici che risolvono verso indirizzi privati o cambiano risoluzione.

Impatto. Tracking involontario; in alcuni modelli di rete, tentativi di accesso a endpoint interni tramite DNS rebinding o risoluzioni non attese.

Raccomandazione. Preferire download controllato e caching locale; applicare allow-list per fonti note o risolvere e rifiutare range privati/link-local a ogni connessione. Disabilitare redirect verso host non ammessi e porre limiti di timeout/byte anche sul download effettivo.

SEC-05 - Foto locali persistite senza rimozione dei metadati

Gravita	MEDIA	Stato	Confermato
Categoria	Privacy immagini	Priorita	P1 - correzione privacy a costo contenuto.

Evidenza. Il servizio valida magic bytes e dimensioni, poi salva i byte originali con nome UUID. Non emerge una fase di decode/re-encode o stripping EXIF/XMP.

Analisi. Le immagini scelte dalla galleria possono contenere coordinate GPS, modello dispositivo, timestamp e altri metadati. Il nome casuale non rimuove tali informazioni.

Impatto. Perdita di informazioni personali quando la directory, un export futuro o un backup di media viene condiviso.

Raccomandazione. Decodificare e ricodificare in un formato controllato eliminando metadata; orientare i pixel prima dello stripping; aggiungere un test con EXIF GPS noto e verificare che il file persistito non lo contenga.

SEC-06 - Validazione immagini basata principalmente sugli header

Gravita	BASSA	Stato	Plausibile
Categoria	Robustezza parser	Priorita	P2 - hardening aggiuntivo.

Evidenza. Test e servizio controllano PNG/JPEG/WebP, dimensioni e pixel attraverso header bounded; non risulta una sanitizzazione completa tramite decoder e ricodifica.

Analisi. Un file può avere intestazioni coerenti ma contenuto corrotto o costruito per sollecitare decoder nativi. I limiti riducono il rischio di decompression bomb, ma non eliminano bug del codec.

Impatto. Crash durante visualizzazione o esposizione a vulnerabilità di librerie di decodifica del sistema.

Raccomandazione. Eseguire decode in isolamento con timeout/limiti e ricodificare. Mantenere aggiornate le librerie native e aggiungere corpus di immagini corrotte/fuzzate.

SEC-07 - Governance dipendenze e supply chain incompleta

Gravita	MEDIA	Stato	Debito tecnico
Categoria	Supply chain	Priorita	P1 - processo continuo.

Evidenza. La checklist richiede ancora revisione advisory. Il log di build segnala 24 pacchetti con versioni piu recenti incompatibili e una futura incompatibilita Kotlin/Flutter per piu plugin.

Analisi. Il lockfile rende riproducibili le versioni correnti, ma non sostituisce scansione CVE, SBOM, controllo licenze e processo di aggiornamento. Le dipendenze native ampliano la superficie di attacco.

Impatto. Ritardo nell adozione di fix di sicurezza, build futura non riproducibile o vulnerabilita note non rilevate.

Raccomandazione. Aggiungere Dependabot/Renovate, OSV-Scanner o equivalente, SBOM CycloneDX, controllo licenze e revisione periodica di pubspec.lock. Trattare gli aggiornamenti come campagne isolate con test completi.

6. Prestazioni e scalabilit 

PERF-01 - Export con getAll() annidati e complessita moltiplicativa

Gravita	ALTA	Stato	Confermato
Categoria	Prestazioni database	Priorita	P0/P1 - prima di promuovere export su storici reali lunghi.

Evidenza. lib/features/transfer/data/total_tracker_transfer_service.dart, _buildFoodExportData e _buildWorkoutExportData: getAll() per collezioni e ulteriori getAll().where(...) dentro i loop di ricette, pasti, routine, piani e sessioni.

Analisi. Ogni padre puo rileggere e materializzare l'intera box dei figli. Con storici grandi il costo cresce approssimativamente come numero_padri x numero_figli e genera molti oggetti temporanei.

Impatto. Export molto lento, garbage collection intensa, consumo batteria e possibile ANR/jank se il lavoro resta sull'isolate UI.

Raccomandazione. Caricare ogni box una sola volta e indicizzare i figli per targetId in Map, oppure usare query ObjectBox su targetId/relazioni con indici. Aggiungere benchmark con 1k/10k/100k record e soglie di regressione.

PERF-02 - Import/export materializza archivi e strutture complete in memoria

Gravita	ALTA	Stato	Confermato
Categoria	Memoria / I/O	Priorita	P0/P1 - legato a PERF-01.

Evidenza. analyzeImport usa file.readAsBytes() e codec.decode(archiveBytes); export costruisce Map completa, codifica l'intero payload in bytes e solo dopo scrive il file temporaneo.

Analisi. I limiti massimi evitano input illimitati, ma il picco di memoria include file compresso, dati espansi, albero JSON, entita/Map intermedie e byte di output. Su dispositivi economici il margine puo essere insufficiente.

Impatto. Out-of-memory, chiusura del processo, UI bloccata o importazione non completata.

Raccomandazione. Passare a lettura/scrittura streaming, entry per categoria e parser incrementale. Eseguire encoding/decoding pesante in isolate. Misurare peak RSS e non soltanto dimensione archivio.

PERF-03 - Applicazione import in una singola transazione sincrona lunga

Gravita	MEDIA	Stato	Confermato
Categoria	Contesa database / responsivita	Priorita	P1.

Evidenza. applyImport esegue tutti gli item selezionati dentro un'unica runInTransaction(TxMode.write).

Analisi. L'atomicita   positiva, ma una transazione molto lunga mantiene lock e lavoro sincrono per tutto il batch. Un archivio grande puo bloccare letture/scritture e non offre avanzamento o cancellazione sicura dopo l'avvio.

Impatto. Jank, timeout percepito, watchdog e recupero difficile in caso di terminazione.

Raccomandazione. Definire una strategia: staging table/store temporaneo e commit finale, oppure batch idempotenti con journal e rollback logico. Eseguire il lavoro fuori dall'isolate UI e mostrare avanzamento.

PERF-04 - File applicativi monolitici aumentano costo e rischio di regressione

Gravita	MEDIA	Stato	Debito tecnico
---------	-------	-------	----------------

Categoria	Manutenibilit� / build	Priorita	P2, con refactor incrementale.
------------------	------------------------	-----------------	--------------------------------

Evidenza. total_tracker_transfer_service.dart: circa 2656 righe/103 KB; food_v01_screens.dart concentra molte schermate e componenti.

Analisi. File molto grandi non sono di per se lenti a runtime, ma aumentano tempi di analisi incrementale, conflitti, difficolt  di review e probabilit  che una modifica trasversale introduca regressioni.

Impatto. Ciclo di sviluppo piu lento e difetti difficili da isolare.

Raccomandazione. Separare codec, mapping, export food, export workout, import analysis e apply. Dividere le schermate per route/feature mantenendo API interne piccole e testabili.

PERF-05 - Mancano benchmark e profili su dataset grandi

Gravita	MEDIA	Stato	Debito tecnico
Categoria	Osservabilit� prestazioni	Priorita	P1 per import/export; P2 per UI generica.

Evidenza. La suite valida correttezza e contratti, ma non risultano benchmark automatizzati per export/import, XLS grandi, ricerca catalogo o ricalcolo di lunghi intervalli.

Analisi. La build debug e i test unitari non misurano frame time, RSS, CPU, durata transazioni o comportamento su storage lento.

Impatto. Regressioni prestazionali rilevate solo dagli utenti o durante importazioni reali.

Raccomandazione. Definire scenari profile/release con dataset sintetici, DevTools timeline/CPU/memory, metriche p50/p95 e budget. Conservare baseline versionate.

PERF-06 - Scheda alimento rallentata da letture N+1 dello storico pasti

Gravita	MEDIA	Stato	Confermato
Categoria	Prestazioni / ObjectBox	Priorita	P1 - correzione inclusa; resta la validazione prestazionale su dataset grandi.

Evidenza. lib/features/nutrition/data/repositories/meal_repository.dart: getIngredientUsage iterava tutti i pasti attivi e richiama getItemsForMeal per ciascuno.

Analisi. Il costo di apertura della scheda alimento cresceva con l'intero storico, anche quando l'ingrediente compariva in pochi pasti. Il ritardo osservato di circa 1-1,5 secondi   coerente con questo pattern. La patch 0.1.0_06 sostituisce la scansione con una query mirata sugli item, raggruppamento per mealId e caricamento dei soli pasti referenziati.

Impatto. Latenza percepibile nella navigazione, maggiore lavoro sul thread UI e peggioramento progressivo al crescere del database.

Raccomandazione. Mantenere la query mirata, verificare che sourceUuid/kindCode siano indicizzati in modo adeguato e aggiungere benchmark con 1.000, 10.000 e 100.000 item. Valutare caricamento asincrono dello storico se la cardinalit  resta elevata.

7. Affidabilit , test e governance

REL-01 - Migrazione Kotlin richiesta da future versioni Flutter

Gravita	MEDIA	Stato	Confermato
Categoria	Build e compatibilit�	Priorita	P1 prima del prossimo upgrade Flutter rilevante.

Evidenza. La build Android del 2026-07-08 avverte che il progetto e i plugin file_picker, mobile_scanner, objectbox_flutter_libs, package_info_plus e workmanager_android applicano Kotlin Gradle Plugin in modo che fallir  in future versioni Flutter.

Analisi. La build corrente passa, ma l'avviso   esplicito e temporalmente limitato. Un upgrade non pianificato della SDK pu  interrompere CI e rilascio.

Impatto. Blocco delle build Android future e ritardo nell'adozione di patch SDK.

Raccomandazione. Congelare la SDK usata dalla release, aprire una campagna separata per Built-in Kotlin, aggiornare i plugin compatibili e verificare debug/release su dispositivo.

REL-02 - Documentazione interna obsoleta e contraddittoria

Gravita	MEDIA	Stato	Confermato
Categoria	Affidabilit� operativa	Priorita	P1 - questa patch corregge la radice, resta il debito nei documenti annidati.

Evidenza. Il README precedente dichiarava workout differito e usava --delete-conflicting-outputs; lib/core/database/README.md descrive ancora schema V1 e funzioni ormai implementate come assenti.

Analisi. Comandi non supportati e scope errato possono portare a code generation differente, decisioni architetturali sbagliate e onboarding fallace.

Impatto. Errori umani, patch basate su assunzioni obsolete e perdita di tempo.

Raccomandazione. Usare il nuovo README come fonte principale, marcare documenti storici con versione/commit, aggiornare o archiviare i README annidati e introdurre test/documentation lint per link e comandi.

REL-03 - Configurazione sensibile del gateway in SharedPreferences

Gravita	MEDIA	Stato	Plausibile
Categoria	Integrit� configurazione	Priorita	P0 insieme a SEC-02.

Evidenza. Endpoint e materiale pubblico di trust runtime sono memorizzati in preferenze applicative quando non forniti a compile time.

Analisi. SharedPreferences   adatto a preferenze, non a garantire integrit  contro device compromesso o backup/manual editing. La chiave   pubblica, ma la sua sostituzione cambia la radice di fiducia.

Impatto. Persistenza silenziosa di configurazione malevola o non pi  valida.

Raccomandazione. Disabilitare override in release; firmare la configurazione o mantenerla compile-time. Mostrare host e key fingerprint nell'UI diagnostica e consentire reset sicuro.

TEST-01 - Copertura insufficiente per fault injection, crash recovery e carico

Gravita	MEDIA	Stato	Debito tecnico
---------	-------	-------	----------------

Categoria	Verifica	Priorita	P1 prima di release stabile.
------------------	----------	-----------------	------------------------------

Evidenza. 189 test e contratti mirati passano, ma l'audit statico non ha trovato campagne dedicate a kill durante transazioni, disco pieno, corruzione ObjectBox, DNS rebinding, archivi al limite e code di invalidazione molto estese.

Analisi. I percorsi nominali sono ben rappresentati; i rischi maggiori rimasti dipendono da condizioni di sistema e volume difficili da simulare con soli unit test.

Impatto. Difetti di recovery e prestazioni non osservati prima del rilascio.

Raccomandazione. Aggiungere test di integrazione su dispositivo/emulatore con fault injection, dataset generator, process kill, clock/timezone change, rete intermittente e storage quasi pieno.

GOV-01 - Licenza del repository non esplicitata nel perimetro esaminato

Gravita	BASSA	Stato	Debito tecnico
Categoria	Governance	Priorita	P2 prima della pubblicazione pubblica.

Evidenza. Nella radice osservata non risulta un file LICENSE citato dal README precedente; il progetto integra dataset e servizi con licenze/attribuzioni proprie.

Analisi. L'assenza di licenza esplicita non è una vulnerabilità runtime, ma rende ambigui riuso, contributi e distribuzione.

Impatto. Rischio legale e difficoltà ad accettare contributi o pubblicare binari/dataset.

Raccomandazione. Scegliere una licenza, aggiungere LICENSE e THIRD_PARTY_NOTICES, documentare licenze Open Food Facts/OpenNutrition e verificare compatibilità delle dipendenze.

REL-04 - Bottom sheet alimenti modale anche quando visivamente compressa

Gravita	MEDIA	Stato	Confermato
Categoria	Usabilità / affidabilità UI	Priorita	P1 - correzione inclusa; obbligatorio test su dispositivi compatti.

Evidenza. Il selettore multiplo usava showModalBottomSheet con DraggableScrollableSheet e snap minimo; la barriera modale restava attiva e il layout compatto poteva eccedere lo spazio disponibile.

Analisi. La compressione visiva non rimuoveva la modalità della route: la pagina sottostante restava non interagibile. La chiusura tramite drag poteva inoltre eliminare lo stato selezionato. La patch 0.1.0_06 usa una bottom sheet persistente senza barriera, conserva alimenti/grammi e mostra una barra compatta esplicita.

Impatto. App apparentemente bloccata, perdita di selezioni, overflow e flusso di inserimento non affidabile.

Raccomandazione. Eseguire widget test su schermi piccoli, tastiera aperta, back di sistema, rotazione e navigazione mentre il pannello è compresso. Mantenere un'altezza minima bounded e un unico controller di sheet.

REL-05 - Grafici e cronologia misurazioni troncavano dati senza dichiararlo

Gravita	MEDIA	Stato	Confermato
Categoria	Completezza dati / UI	Priorita	P1 - correzione inclusa; resta il test di usabilità e carico.

Evidenza. measurement_screens.dart limitava peso e grasso a take(12) e mostrava separatamente take(6) per bilancia e metro.

Analisi. L'utente poteva interpretare un grafico parziale come serie completa. Date e valori erano poco leggibili e il filtro temporale era collocato dopo i grafici. La patch 0.1.0_06 usa tutti i punti nell'intervallo, espone data e valore,

applica i filtri ai grafici e combina la cronologia con paginazione da 15.

Impatto. Interpretazione incompleta dei trend, impossibilita di consultare tutto lo storico dalla pagina principale e incoerenza tra filtri e grafici.

Raccomandazione. Aggiungere test con intervalli inclusivi, giorni duplicati, valori mancanti e oltre 30 registrazioni. Per storici molto lunghi valutare downsampling visuale senza eliminare i dati consultabili.

REL-06 - Drift di pubspec.lock blocca le patch senza una politica di preservazione

Gravita	BASSA	Stato	Confermato
Categoria	Riproducibilita / supply chain	Priorita	P2 - politica operativa inclusa nel launcher.

Evidenza. Il launcher documentale 0.1.0_06 si e fermato in preflight con Unexpected dirty file: pubspec.lock dopo flutter pub get della patch precedente.

Analisi. Il blocco fail-fast e corretto, ma un lockfile generato localmente deve essere classificato, salvato e normalizzato in modo esplicito per evitare falsi blocchi o perdita di informazioni. La nuova patch accetta solo drift noto, ne registra hash e copia byte-for-byte, poi ripristina la versione Git prima del probe.

Impatto. Interruzione del workflow, possibili differenze dipendenze non comprese o tentazione di forzare il launcher ignorando il working tree.

Raccomandazione. Conservare il lockfile nel risultato di audit, confrontarlo semanticamente con HEAD e non includere variazioni di dipendenze nella patch se non motivate. CI deve verificare che flutter pub get non produca drift inatteso.

8. Piano di remediation proposto

Fase A - Confini di fiducia e riservatezza

- Portare OPENNUTRITION_ALLOW_CUSTOM_GATEWAY a false per default e separare esplicitamente debug/release.
- Fissare host e chiave pubblica di produzione; aggiungere fingerprint visibile e procedura di rotazione/revoca.
- Definire formato .totaltracker v3 cifrato e autenticato mantenendo import read-only delle versioni precedenti.
- Decidere threat model e politica del database locale; documentare cosa è protetto e cosa non lo è.

Fase B - Prestazioni dei trasferimenti

- Sostituire getAll() annidati con query o preindicizzazione in memoria eseguita una sola volta per box.
- Separare encoder/decoder per categoria e adottare streaming o chunk con limiti espliciti.
- Spostare parsing e serializzazione pesante in isolate; non trasferire grafi duplicati non necessari.
- Introdurre dataset generator e benchmark di tempo, memoria e dimensione output.

Fase C - Immagini e rete

- Download bounded con redirect policy e verifica DNS/IP finale.
- Decode, orientamento e re-encode senza metadata per immagini locali.
- Corpus di immagini corrotte e test di timeout/decoder failure.

Fase D - Release engineering

- Migrazione Built-in Kotlin in branch dedicato.
- SCA/SBOM/licenze in CI e calendario aggiornamenti.
- Fault injection su processo, rete, disco, clock e database.
- Riallineamento dei README annidati e archiviazione dei documenti storici.

Criteri di uscita consigliati

Area	Criterio minimo
Export	Archivio cifrato; round-trip cross-device; password errata non rivela dati; versioni legacy gestite.
Gateway	Override runtime assente in release; host/key pinned; rotazione testata.
Prestazioni	Export/import dataset target senza OOM; p95 e peak RSS entro budget documentato.
Immagini	EXIF rimosso; redirect/DNS policy testata; decoder failure gestita.
Database	Threat model approvato e decisione cifratura documentata.
Build	SDK/plugin aggiornati; warning Kotlin risolto; CI verde.
Test	Fault injection e matrice dispositivi completate con evidenze versionate.

9. Evidenze di qualita disponibili

La patch funzionale precedente e stata applicata con probe detached e successiva ripetizione sulla repository reale. Il log fornito riporta:

- ObjectBox generation e controllo di riproducibilita: PASS.
- flutter analyze: PASS, nessun rilievo.
- Test mirati: 12/12 PASS.
- Suite completa: 189/189 PASS.
- Build Android debug: PASS.
- Commit e push del branch dedicato: PASS.
- Merge main: non eseguito.

Queste evidenze riducono il rischio di regressioni funzionali immediate, ma non rispondono ai quesiti di confidenzialita, performance di volume e resilienza a fault di sistema. Per tali aree servono test dedicati.

Warning di toolchain da preservare nel backlog

La build passa ma Flutter avverte che l'applicazione diretta del Kotlin Gradle Plugin nel progetto e in piu plugin causara fallimenti con versioni future. Non e un errore corrente; e un rischio di compatibilita confermato.

10. Riferimenti

- **Repository e baseline.** <https://github.com/RaffyManzo/Total-Tracker---Nutrition-measurement-and-workout> - commit 87a2b8d58dea240f0b4b69dddc76e620b1a4729.
- **Checklist interna.** docs/SECURITY_AND_RELEASE_CHECKLIST.md.
- **Trasferimenti.** lib/features/transfer/data/total_tracker_transfer_service.dart.
- **Database.** lib/core/database/objectbox_database.dart e lib/objectbox-model.json.
- **Immagini.** servizio di storage immagini ingredienti e relativi test di sicurezza.
- **OpenNutrition.** configurazione/gateway client, policy di rete e test risposta firmata.
- **OWASP MASVS - Storage.** <https://mas.owasp.org/MASVS/05-MASVS-STORAGE/>.
- **OWASP MASTG - Local storage.**
<https://mas.owasp.org/MASTG/tests/android/MASVS-STORAGE/MASTG-TEST-0001/>.
- **Android - backup security.** <https://developer.android.com/privacy-and-security/risks/backup-best-practices>.
- **Android - secure network protocols.** <https://developer.android.com/privacy-and-security/security-ssl>.
- **Android Keystore.** <https://developer.android.com/privacy-and-security/keystore>.
- **Flutter performance.** <https://docs.flutter.dev/perf/ui-performance> e <https://docs.flutter.dev/tools/devtools/performance>.
- **Flutter background parsing.** <https://docs.flutter.dev/cookbook/networking/background-parsing>.
- **ObjectBox queries/relations/transactions.** <https://docs.objectbox.io/queries>, [/relations](https://docs.objectbox.io/relation) e [/transactions](https://docs.objectbox.io/transactions).

Conclusione

Total Tracker dispone di basi robuste per continuare lo sviluppo. La priorit  non   aggiungere altri controlli generici, ma chiudere i confini di fiducia gi  individuati e misurare i percorsi che oggi scalano male. La distinzione tra rischio confermato, plausibile e debito tecnico deve essere mantenuta anche nelle patch successive.